

Phase 1 Architecture

System: EHR Threat Detection Pipeline

Objective: To design a pipeline capable of detecting anomalous activities in Electronic Health Record (EHR) systems and identifying the underlying mechanism of attack by integrating CAPEC-driven ontology, behavioral fingerprinting, and probabilistic modeling.

1. Overview

The proposed EHR Threat Detection Pipeline captures, processes, and analyzes logs generated by healthcare systems. Unlike traditional log anomaly detection approaches that focus only on isolated suspicious events, this architecture incorporates behavioral fingerprinting, CAPEC ontology, and probabilistic models to identify full attack mechanisms.

2. Data Flow

The data flow in Phase 1 consists of the following steps:

1. Raw Log Collection

- Source: EHR access logs, system events, file operations, media interactions.
- Input: Raw, unstructured log files.

2. Parsing and Normalization

- Logs are cleaned and standardized into a structured format.
- Outputs:
 - `events.csv` → tabular suspicious events.
 - `user_sessions.json` → user-specific ordered sequences of activities.
 - `session_graph.graphml` / Neo4j → graph-based representation of sessions.

3. Behavioral Fingerprinting

- **Rule-based fingerprinting (symptoms):** Detects simple suspicious events such as odd-hour logins, USB writes, or configuration changes. Stored in `events.csv` with abnormality scores.
- **Sequence-based fingerprinting (behaviors):** Constructs action sequences, e.g.,

```
logon_failure → logon_failure → logon_success → file_copy_usb
```

Stored in JSON or graph databases. These sequences provide input for probabilistic models (Markov Chains/HMM).

4. Ontology and CAPEC Templates

- **Ontology Graph (Neo4j/GraphML):**
 - Nodes: CAPEC IDs, CWE IDs, CVE IDs.
 - Edges: ParentOf, ChildOf, CanFollow, CanPrecede.
- **CAPEC Templates (FSMs):** Execution flows derived from CAPEC attack patterns (e.g., CAPEC-118: login → file copy → logout). Stored as JSON or graph-based finite state machines.
- **Integration:** CAPEC ↔ CWE ↔ CVE mapping enriches the ontology with vulnerability and weakness data.

5. Normal Behavior Modeling (Markov/HMM)

- States: User activities (e.g., login_success, file_open, usb_write).
- Transitions: Probabilities of one activity following another.
- Training data: Validated normal workflows, excluding CAPEC-like attack traces.
- Purpose: Establish a baseline probability model of expected user activity.

6. NLP Layer (TF-IDF Analysis)

- Applied on textual log fields and CAPEC descriptions.
- Identifies rare but relevant healthcare-specific tokens (e.g., `dicom_service_restart`).
- Provides an additional anomaly detection signal.

3. Detection Workflow

The detection workflow in Phase 1 proceeds as follows:

1. Logs are ingested and parsed into structured formats.
 2. The rules engine filters and flags suspicious events (symptom-level).
 3. Logs are sessionized into ordered user sequences (JSON/Graph).
 4. Probabilistic models (HMM/Markov) score session probabilities:
 - High probability → normal session.
 - Low probability → candidate anomaly.
 5. Sequence mining and graph matching (VF2 subgraph matching, graph edit distance) compare anomalous sessions against CAPEC templates.
 6. Detection outcomes:
 - Exact match → confirmed attack (CAPEC ID assigned).
 - Partial match → precursor detection (attack in progress).
 7. Anomaly logs store metadata such as session ID, probability score, CAPEC ID, and severity.
 8. Dashboard provides visualization of user activity paths mapped against CAPEC templates.
-

4. Storage Strategy

Layer	Storage Format	Purpose
Events (symptoms)	CSV (<code>events.csv</code>)	Lightweight tabular event tracking
User Sessions (sequences)	JSON (<code>user_sessions.json</code>) / MongoDB	Flexible schema for ordered activities
Behavior Graphs	GraphML / Neo4j	Rich sequence representation, CAPEC matching
Ontology	Neo4j / NetworkX Graph	Hierarchical attack ontology with CVE/CWE links
Anomaly Logs	SQL / JSON	Persistent storage of detected threats

5. Detection Scope

- **Rules Engine:** Detects suspicious user actions (symptoms).
- **HMM/Markov Models:** Detect statistical anomalies in user activity sequences.
- **CAPEC Templates:** Detect structured attack mechanisms and strategies.

Final Output: Detection results are presented at the mechanism-of-attack level.

Example:

"Session matches CAPEC-112 (Brute Force): multiple failed logins followed by a successful login."

6. Summary

Phase 1 establishes the foundation of the EHR Threat Detection Pipeline with the following contributions:

- Behavioral fingerprinting at both event (symptom) and sequence (behavior) levels.
- Multi-format data storage: CSV for rules, JSON for sessions, Graph DB for ontology.
- CAPEC-based templates modeled as finite state machines, enriched with CWE and CVE data.
- Probabilistic models trained on verified non-malicious logs for baseline behavior.
- TF-IDF analysis for healthcare-specific rare command detection.
- A unified detection pipeline integrating filtering, anomaly scoring, CAPEC matching, and anomaly logging.
- An explainable detection framework that identifies attack mechanisms rather than isolated anomalies.